BSI Group BSI Group BSI Group

bsi

<<organization>>

Supplier Assessment Questionnaire

BSIIndia

Inspiring trust for a more resilient world.

 ©The British Standards Institution 2024

BSI Group BSI Group BSI Group

BSI Group BSI Group BSI Group

Contents

Document Control 3
Version History 3
Reviewers 3
Questionnaire 4
Background 4
How to Use 4

BSIIndia

Document ID	Version and Date	Changes	Updated By	Approved By	Data Classification
IAMS/0013	Version 4.0 July 20XX	Updated to include AI	John Doe	Jenny Doe	Internal

 ©The British Standards Institution 2024

BSI Group BSI Group BSI Group

BSI Group BSI Group BSI Group

Document Control

This document is the responsibility of the Author. It is subject to formal change control after the initial approved release (e.g. version 1.0). Change requests must be communicated to the Author in writing. Agreed changes are recorded in the Version History of the document.

Version History

Date	Version	Author	Changes
12/05/20YY	0.1	John Doe	New Document – initial draft
20/06/20YY	0.2	John Doe	Stakeholder comments
01/07/20YY	1.0	John Doe	Issued to Business
02/04/20ZZ	1.1	John Doe	Update for new supplier questions
19/03/20ZZ	1.2	John Doe	Stakeholder comments
01/03/20ZZ	2.0	John Doe	Issued to Business
16/07/20ZZ	2.1	John Doe	PCI compliance questions added
01/09/20ZZ	3.0	John Doe	Issued to Business
14/04/20XX	3.1	John Doe	AI questions added
16/05/20XX	3.2	John Doe	Stakeholder comments
01/07/20XX	4.0	John Doe	Issued to Business

Reviewers

Name	Role	Date
Jenny Doe	Head of Procurement	01/07/20XX

Document ID	Version and Date	Changes	Updated By	Approved By	Data Classification
IAMS/0013	Version 4.0 July 20XX	Updated to include AI	John Doe	Jenny Doe	Internal

 ©The British Standards Institution 2024

BSI Group BSI Group BSI Group

BSI Group BSI Group BSI Group

Questionnaire

Background

- This questionnaire is for use by Procurement in assessing the suitability of potential third-party suppliers to deliver services to <<organization>>. In addition to regular business operations, the questionnaire encompasses requirements related to external certifications that are assessed by other teams within <<organization>>, as follows:
    - Regular business operations, assessed by Procurement
    - Information Security (ISO 27001) and Data Protection, assessed by Cybersecurity
    - Payment Card Industry Data Security Standard (PCI DSS), assessed by Finance Operations
    - Artificial Intelligence (ISO 42001), assessed by Risk and Compliance.

How to Use

- The questionnaire table (Annex A) is also provided in an Excel spreadsheet, <<reference>> Supplier Assessment Questionnaire, which includes additional sheets and columns for the scoring of answers.
- The <<reference>> Supplier Assessment Questionnaire spreadsheet is submitted to third parties for completion and to be returned to Procurement for assessment.
- Procurement will distribute the completed questionnaire to stakeholders for review and will coordinate with stakeholders to arrive at an overall conclusion on whether the third party can be engaged.
- Records of the assessment are recorded collated together with other information regarding the third party and are maintained per the <<reference>> Third Party Management Process.

Document ID	Version and Date	Changes	Updated By	Approved By	Data Classification
IAMS/0013	Version 4.0 July 20XX	Updated to include AI	John Doe	Jenny Doe	Internal

 ©The British Standards Institution 2024

BSI Group BSI Group BSI Group

BSI Group BSI Group BSI Group

#	Ordinal	Control Area	Question	Response	Response Date
1	1	Supplier relationship details	How long have you held a relationship with <<organization>> (years) or is this a new relationship?		
2	2	Supplier relationship details	What are the high-level business services you provide to <<organization>>?		
3	3	Supplier relationship details	How is information transferred/shared with <<organization>>?		
4	4	Supplier relationship details	What is your full company name?		
5	5	Supplier relationship details	Where is your head office located?		
6	6	Supplier relationship details	What categories of data do you process for <<organization>>?		
7	7	Supplier relationship details	Do you physically visit <<organization's>> premises?		
8	1	Governance	What is your registered address?		
9	2	Governance	What is your main contact email address?		
10	3	Governance	Please provide contact details: Telephone (switchboard, DDI and mobile where applicable).		
11	4	Governance	Do you maintain a security programme based upon a recognised standard? If so, please state which, e.g., ISO 27001, BS 10012, PCI-DSS, Cyber Security Essentials/Essentials Plus		
12	5	Governance	Is your organization formally certified to ISO 27001? If so, please provide details of the scope of the certification and certification number		
13	6	Governance	Do you maintain an artificial intelligence (AI) programme based upon a recognised standard? If so, please state which, e.g., ISO 42001		
14	7	Governance	Is your organization formally certified to ISO 42001? If so, please provide details of the scope of the certification and certification number		

Document ID	Version and Date	Changes	Updated By	Approved By	Data Classification
IAMS/0013	Version 4.0 July 20XX	New documentation	John Doe	Jenny Doe	Internal

©The British Standards Institution 2024

BSI Group BSI Group BSI Group

BSI Group BSI Group BSI Group

15	8	Governance	Is there senior management oversight and approval of your information security/ AI / information governance or privacy management system? If so, please provide details		
16	9	Governance	Have you defined and appointed a data custodian or 'information ownership' for all <<organization>> data assets? If so, please provide details		
17	10	Governance	How are policies distributed/made available to staff?		
18	11	Governance	Do you screen your employees for criminal or financial irregularities before and/or during employment? If so, please provide details		
19	12	Governance	Do your staff receive annual security, data protection and AI awareness training? How are levels of awareness maintained throughout the year?		
20	13	Governance	How do you monitor that adequate protection of <<organization>> data is sustained?		
21	14	Governance	Is there an information security management, AI management and information governance programme in place? If so, please provide details		
22	15	Governance	Do you have an approved and published information security, AI, information governance and data protection policy? If so, please provide details		
23	15a	Governance	How often are these policies updated?		
24	15b	Governance	When were they last reviewed?		
25	16	Governance	Do your employees (including contractors, associates and consultants) sign to acknowledge receipt of data protection, security and AI policies?		
26	17	Governance	Do job descriptions include AI, security and privacy responsibilities and competencies, particularly for those in an enhanced position of trust, e.g., IT administrators, data managers, those overseeing AI ethics and data quality, those granted access to personal data and sensitive business data and other privileged account holders?		

Document ID	Version and Date	Changes	Updated By	Approved By	Data Classification
IAMS/0013	Version 4.0 July 20XX	New documentation	John Doe	Jenny Doe	Internal

©The British Standards Institution 2024

BSI Group BSI Group BSI Group

BSI Group BSI Group BSI Group

27	18	Governance	Does your organization fully comply with the Data Protection Act (DPA) 2018 where applicable to the services provided?		
28	19	Governance	If you provide payment processing services on behalf of <<organization>>, does your organization fully comply with the Payment Card Industry Data Security Standard (PCI-DSS)?		
29	20	Governance	Have you published policies, standards and processes in the areas of DPA and PCI DSS compliance and have they been made available to all staff required to comply with them? If so, please provide details		
30	21	Governance	Do you have responsibility for AI ethics assigned at a senior level within your organization?		
31	22	Governance	If providing an AI system / SAS solution, have you undertaken an AI impact assessment for the system? If so, please confirm whether the impact assessment has been conducted in accordance with a recognized standard, such as ISO 42005?		
32	1	AI Data Management	Do you have a data management team and process in place?		
33	2	AI Data Management	What steps do you take to establish provenance of data used by AI models?		
34	3	AI Data Management	How do you ensure adequate distribution and completeness of data within AI datasets (e.g., exploration, cleaning, normalization and scaling)?		
35	4	AI Data Management	What techniques do you employ to enhance or label data used within AI datasets?		
36	5	AI Data Management	If engaged in AI model development, do you maintain separate and disjoint training, validation and test datasets?		
37	1	AI Quality Management	Do you undertake regular data quality audits? If so, how frequently are they conducted?		
38	2	AI Quality Management	Do data quality audits consider all the data quality characteristics as set out in ISO 42005 (Accuracy, Completeness, Representativeness, Consistency, Credibility, Currentness, Accessibility, Compliance,		

Document ID	Version and Date	Changes	Updated By	Approved By	Data Classification
IAMS/0013	Version 4.0 July 20XX	New documentation	John Doe	Jenny Doe	Internal

©The British Standards Institution 2024

BSI Group BSI Group BSI Group

BSI Group BSI Group BSI Group

			Efficiency, Precision, Understandability, Portability, Auditability, Identifiability, Effectiveness, Balance, Diversity, Relevance, Similarity and Timeliness)?		
39	3	AI Quality Management	Do data quality audits ensure avoidance of algorithmic bias, reproducibility and robustness of models?		
40	4	AI Quality Management	Do you evaluate models for the presence of unwanted bias and compliance with fairness and transparency guidelines?		
41	5	AI Quality Management	Do you evaluate AI model performance on an ongoing basis?		
42	6	AI Quality Management	Is AI model performance evaluated using established performance measures (such as accuracy, F1 score, AUC-ROC)?		
43	1	Physical Security & Resilience	Do you have a documented physical security policy?		
44	2	Physical Security & Resilience	What physical access controls do you have for staff gaining access to your premises/ locations?		
45	3	Physical Security & Resilience	What physical access controls do you have for visitors gaining access to your premises/ locations?		
46	4	Physical Security & Resilience	Is CCTV monitoring deployed to protect the processing location(s)? Please describe procedures for the storage and release of CCTV images.		
47	5	Physical Security & Resilience	Are computer rooms and local office server rooms located away from main business/general and public access areas with auditable restricted access that can verify entry?		
48	6	Physical Security & Resilience	Are all other work zones used for processing personal data and sensitive data protected by internal access control?		
49	7	Physical Security & Resilience	Do you operate a clear desk & clear screen policy?		
50	8	Physical Security & Resilience	Are there documented procedures and approved methods for the secure destruction of sensitive documentation and waste paper?		
51	9	Physical Security & Resilience	Is equipment awaiting sanitization and secure disposal protected e.g., locked compound or		

Document ID	Version and Date	Changes	Updated By	Approved By	Data Classification
IAMS/0013	Version 4.0 July 20XX	New documentation	John Doe	Jenny Doe	Internal

©The British Standards Institution 2024

BSI Group BSI Group BSI Group

BSI Group BSI Group BSI Group

			cupboard pending collection/destruction? If so, please provide details		
52	10	Physical Security & Resilience	Are arrangements in place for the allocation and storage of physical keys, e.g. key sign-out logs and physical key storage, including back-up physical keys for any media safes in use.? If so, please provide details		
53	11	Physical Security & Resilience	Are computer rooms and equipment protected by UPS and are arrangements for back-up power available, e.g. generator/dual service power? If so, please provide details		
54	12	Physical Security & Resilience	Are premises monitored by a building management system, door alarms and alarms regularly tested and maintained? If so, please provide details		
55	13	Physical Security & Resilience	Are service location premises owned, shared or leased?		
56	14	Physical Security & Resilience	Is evidence of routine physical/mechanical maintenance and inspection kept up to date, e.g. smoke alarms, fire extinguishers, generator testing?. If so, please provide details		
57	15	Physical Security & Resilience	What steps do you take to minimize the impact on climate change from your mechanical and electrical utilities?		
58	1	IT Operations	Do computer systems processing sensitive or personal data enforce the use of strong and complex passwords with a minimum of 8 characters? If so, please provide details		
59	2	IT Operations	Have you implemented a robust account lockout policy? If so, please provide your standard settings		
60	3	IT Operations	If engaged in software development, do you have segregated production, test and development environments?		
61	4	IT Operations	If engaged in AI software development, do you segregate access to training, validation and test datasets?		

Document ID	Version and Date	Changes	Updated By	Approved By	Data Classification
IAMS/0013	Version 4.0 July 20XX	New documentation	John Doe	Jenny Doe	Internal

©The British Standards Institution 2024

BSI Group BSI Group BSI Group

BSI Group BSI Group BSI Group

62	5	IT Operations	Is the use of external/freeware data exchange and communication services (e.g. Dropbox, Skype etc.) for <<organization>> data processing by staff prohibited unless expressly authorized?		
63	6	IT Operations	Is the use of private/personal external data storage services by staff prohibited unless expressly authorized? (e.g. iCloud/SkyDrive etc)		
64	7	IT Operations	Is all computer hardware, data storage and backup media properly 'data cleansed' prior to re-use and/or destroyed when the information is no longer required? If so, please provide details		
65	8	IT Operations	Are permanent electronic file shredding and/or physical destruction tools used?		
66	9	IT Operations	If a third-party organization provides equipment and media destruction on your behalf, do you retain evidence of (certificates of) destruction?		
67	10	IT Operations	Do you use password safe tools (e.g. KeePass or similar) to provide encryption and storage of privileged level passwords? If so, please provide details		
68	11	IT Operations	Do you have individuals within your organization who conduct internal information security and AI management system audits?		
69	12	IT Operations	Is software running on computers connecting to the Internet fully licensed and supported (by the software vendor or supplier of the software) to ensure security patches for known vulnerabilities are made available?		
70	13	IT Operations	Has outdated or older software been removed from computer and network devices that are connected to or capable of connecting to the internet?		

Document ID	Version and Date	Changes	Updated By	Approved By	Data Classification
IAMS/0013	Version 4.0 July 20XX	New documentation	John Doe	Jenny Doe	Internal

©The British Standards Institution 2024

BSI Group BSI Group BSI Group

BSI Group BSI Group BSI Group

71	14	IT Operations	Has anti-virus or malware protection software been installed on all computers that are connected to or capable of connecting to the internet? Has anti-virus or malware protection software (including program/engine code and malware signature files) been kept up to date (either by 11onfigureng it to update automatically or using centrally managed services)?		
72	15	IT Operations	Do you have an incident responses plan? Does the plan include procedures to notify <<organization>> of actual or suspected security incidents and data? If so, please provide details		
73	16	IT Operations	Have you defined a secure and ethical development process that covers the secure development of software, ethical considerations for the development of AI systems and efficient coding to minimize climate change impact?		
74	1	Contingency Planning	Do you have business continuity (BC) and disaster recovery (DR) plans?		
75	1a	Contingency Planning	How often are these plans tested?		
76	1b	Contingency Planning	How are these tests conducted?		
77	2	Contingency Planning	Is your BCP programme based upon a recognized standard, e.g., ISO 22301? If so, please provide details.		
78	3	Data Protection and GDPR	Are you registered with the Information Commissioner's Office (or equivalent supervisory authority if outside the UK) with respect to data protection as a data controller?		
79	4	Data Protection and GDPR	Do you export (or grant actual or potential access to) any <<organization>> personal data or confidential business assets outside the UK?		
80	4a	Data Protection and GDPR	If so, where to?		
81	4b	Data Protection and GDPR	If outside the EEA or other EU approved (adequacy) countries, are the required legal agreements in place, e.g. standard contractual clauses?		

Inspiring trust for a more resilient world.

 ©The British Standards Institution 2024

BSI Group BSI Group BSI Group

BSI Group BSI Group BSI Group

82	5	Data Protection and GDPR	How will you notify <<organization>> of changes to the data?		
83	6	Data Protection and GDPR	What legal basis do you use to process <<organization>> data?		
84	7	Data Protection and GDPR	Has your business been the subject of any security investigation or complaint for non-compliance by any European data protection authority? If so, please provide details.		
85	8	Data Protection and GDPR	Has your business been the subject of any complaint or lawsuit from private parties relating to compliance? E.g. ISO 22301		
86	9	Data Protection and GDPR	Has your business been the subject of any media report relating to how your organization handles personal data? If so, please provide details		
87	10	Data Protection and GDPR	Has your business suffered any data security breaches in the last five years? Please indicate approximate numbers of breaches in this time (e.g., less than five, less than 10, 11-50, 50+)		
88	1	Evidence of Controls Documents	Please attach a copy of your Information Security Policy and supporting standards, or tables of contents.		
89	2	Evidence of Controls Documents	Please attach a copy of your AI Policy and supporting standards, or tables of contents.		
90	3	Evidence of Controls Documents	Please attach a copy of your PCI-DSS Attestation of Compliance (if applicable).		
91	4	Evidence of Controls Documents	Please attach a copy of your Acceptable Usage Policies (IT, Email, Internet, Mobile computing, BYOD, Social Networking, AI).		
92	5	Evidence of Controls Documents	Please attach a copy of your Change Management Policy.		
93	6	Evidence of Controls Documents	Please attach a copy of your Incident Response Plan.		
94	7	Evidence of Controls Documents	Please attach a copy of your Security Incident Management & Investigations Policy.		

Document ID	Version and Date	Changes	Updated By	Approved By	Data Classification
IAMS/0013	Version 4.0 July 20XX	New documentation	John Doe	Jenny Doe	Internal

©The British Standards Institution 2024

BSI Group BSI Group BSI Group

BSI Group BSI Group BSI Group

95	8	Evidence of Controls Documents	Please attach a copy of your topic-specific AI policies, including those covering responsible AI development and deployment, ethical data usage for AI, eliminating algorithmic bias, AI model transparency and explainability, AI Monitoring, Reporting and Improvement, as applicable.		
96	9	Evidence of Controls Documents	Please attach a copy of your BCP/DR Plans.		
97	10	Evidence of Controls Documents	Please attach a copy of your Home Working Policy.		
98	11	Evidence of Controls Documents	Please attach a copy of your Information Governance Policy.		
99	12	Evidence of Controls Documents	Please attach a copy of your Data Protection Policy.		
100	13	Evidence of Controls Documents	Please attach a copy of your Data Retention (Records Management), Sanitisation & Disposal Policy.		
101	14	Evidence of Controls Documents	Please attach a copy of your Information Ownership & Classification Policy.		
102	15	Evidence of Controls Documents	Please attach a copy of your Media Handling Policy.		
103	16	Evidence of Controls Documents	Please attach a copy of your ISO/IEC 27001:2022 certification.		
104	17	Evidence of Controls Documents	Please attach a copy of your ISO/IEC 42001:2023 certification.		
105	18	Evidence of Controls Documents	Please attach a copy of your Datacentre SSAE 16/Type II Report evidence (Certificate or Statement of Compliance).		
106	19	Evidence of Controls Documents	Please attach a copy of your Physical Security Policy or Table of Contents.		
107	20	Evidence of Controls Documents	Please attach a copy of your High Level Network Diagram (sanitised) but illustrating network architecture and dataflows involving AI and personal data assets.		

Document ID	Version and Date	Changes	Updated By	Approved By	Data Classification
IAMS/0013	Version 4.0 July 20XX	New documentation	John Doe	Jenny Doe	Internal

©The British Standards Institution 2024

BSI Group BSI Group BSI Group